

07_Authentication_Design.md

Document Information

Project: Blogging System API

Version: 1.0

Introduction

This document describes the authentication and authorization design of the Blogging System API.

The authentication module is responsible for:

- User registration
 - Email verification using OTP
 - Login
 - JWT authentication
 - Refresh token management
 - Password reset
 - Password change
-

Authentication Components

- JWT Access Token
 - Refresh Token
 - BCrypt Password Hashing
 - SMTP Email Service
 - OTP Verification
 - Role-Based Authorization (RBAC)
-

Registration Flow

1. User submits:
2. First Name
3. Surname

4. Email
 5. Password
 6. Password is validated.
 7. Password is hashed using BCrypt.
 8. User account is created with `IsVerified = false`.
 9. A six-digit OTP is generated.
 10. OTP is stored in the `Otps` table.
 11. OTP is sent to the user's email using SMTP.
 12. User submits the OTP.
 13. The account is marked as verified.
-

Login Flow

1. User submits email and password.
 2. System locates the user by email.
 3. Password hash is verified using BCrypt.
 4. User verification status is checked.
 5. JWT Access Token is generated.
 6. Refresh Token is generated and stored.
 7. Tokens are returned to the client.
-

Forgot Password Flow

1. User submits email.
 2. A Password Reset OTP is generated.
 3. OTP is stored in the `Otps` table.
 4. OTP is sent via email.
 5. User submits:
 6. Email
 7. OTP
 8. New Password
 9. OTP is validated.
 10. Password is hashed.
 11. PasswordHash is updated.
-

Change Password Flow

Authenticated users may change their password by supplying:

- Current Password
- New Password

The current password must be validated before the password hash is updated.

JWT Design

Access Token

Purpose:

- Authenticate API requests.

Contains:

- User Id
- Email
- Role

The Access Token shall have a configurable expiration time.

Refresh Token

Purpose:

- Obtain a new Access Token without requiring the user to log in again.

Refresh Tokens are stored in the database and invalidated when revoked or expired.

Authorization

The system implements Role-Based Access Control (RBAC).

User

Permissions:

- Read published posts
- Comment
- Reply
- Delete own comments
- View profile
- Update profile
- Change password

Administrator

Permissions:

- Create posts
- Edit own posts
- Delete own posts
- Save drafts
- Publish drafts
- Lock and unlock comments
- Reply to comments
- Delete any comment
- Change password

Password Policy

Passwords must:

- Be at least 8 characters long.
- Include one uppercase letter.
- Include one lowercase letter.
- Include one number.
- Include one special character.

Passwords are never stored in plain text.

Security Principles

- BCrypt hashing
- JWT authentication
- Refresh Token validation

- OTP verification
 - Role-based authorization
 - Input validation
 - Secure configuration using environment variables
-

08_Logging_and_Observability.md

Introduction

The Blogging System API uses OpenTelemetry to improve observability during development.

Objectives

- Trace incoming requests
 - Monitor database operations
 - Capture exceptions
 - Log application events
-

Instrumentation

The application shall instrument:

- HTTP Requests
 - Entity Framework Core
 - Database Calls
 - Exceptions
 - Authentication Events
-

Exporter

Development telemetry shall be exported to the console.

No external telemetry collector is required for Version 1.

Logging Guidelines

Log:

- Application startup
- Application shutdown
- User registration
- Login attempts
- Successful logins
- Failed logins
- Password resets
- Database failures
- Unexpected exceptions

Do **not** log:

- Passwords
- Password hashes
- JWT tokens
- Refresh tokens
- OTP codes

Benefits

OpenTelemetry assists with:

- Debugging
- Performance monitoring
- Request tracing
- Error diagnosis
- Development visibility